

VULNERABILITY ASSESSMENT REPORT

Target Application: OWASP Juice Shop

Tools Used: Nmap, OWASP ZAP, Browser DevTools

Prepared By: Shreshta S S

Date: (Add today's date)

EXECUTIVE SUMMARY

This report presents the results of a vulnerability assessment conducted on the OWASP Juice Shop application. The assessment aimed to identify common security weaknesses and evaluate potential risks.

Several vulnerabilities were discovered, including missing security headers, session management issues, and information disclosure. While no critical vulnerabilities were found, multiple medium-risk issues could be exploited if left unaddressed.

Addressing these issues will improve the application's security posture and reduce the risk of potential attacks.

TOOLS USED

- Nmap – Network scanning
- OWASP ZAP – Vulnerability detection
- Browser DevTools – Request/response analysis

FINDINGS SUMMARY TABLE

Vulnerability	Risk Level
Missing Anti-clickjacking Header	Medium
Session ID in URL	Medium
Missing X-Content-Type-Options Header	Medium
Server Version Disclosure	Low
Information Disclosure (Comments)	Low
Open Port 3000	Low

FINDING 1

Vulnerability: Missing Anti-clickjacking Header

Risk Level: Medium

Description:

The application does not include protections against clickjacking attacks.

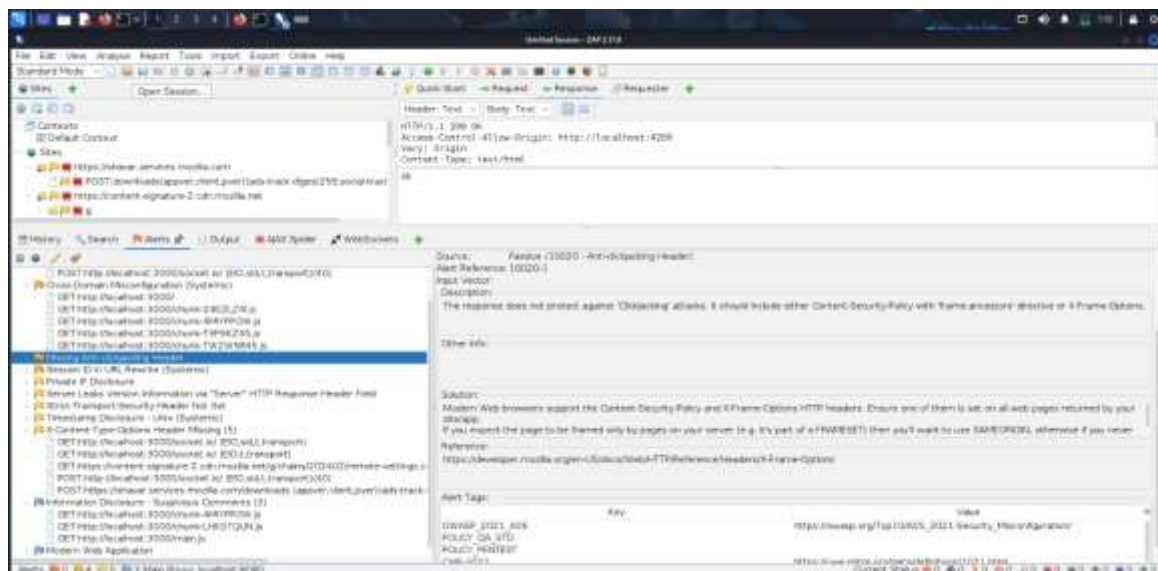
Impact:

Attackers can trick users into clicking hidden elements, leading to unauthorized actions.

Recommendation:

Implement security headers such as:

- X-Frame-Options
- Content-Security-Policy



FINDING 2

Vulnerability: Session ID in URL

Risk Level: Medium

Description:

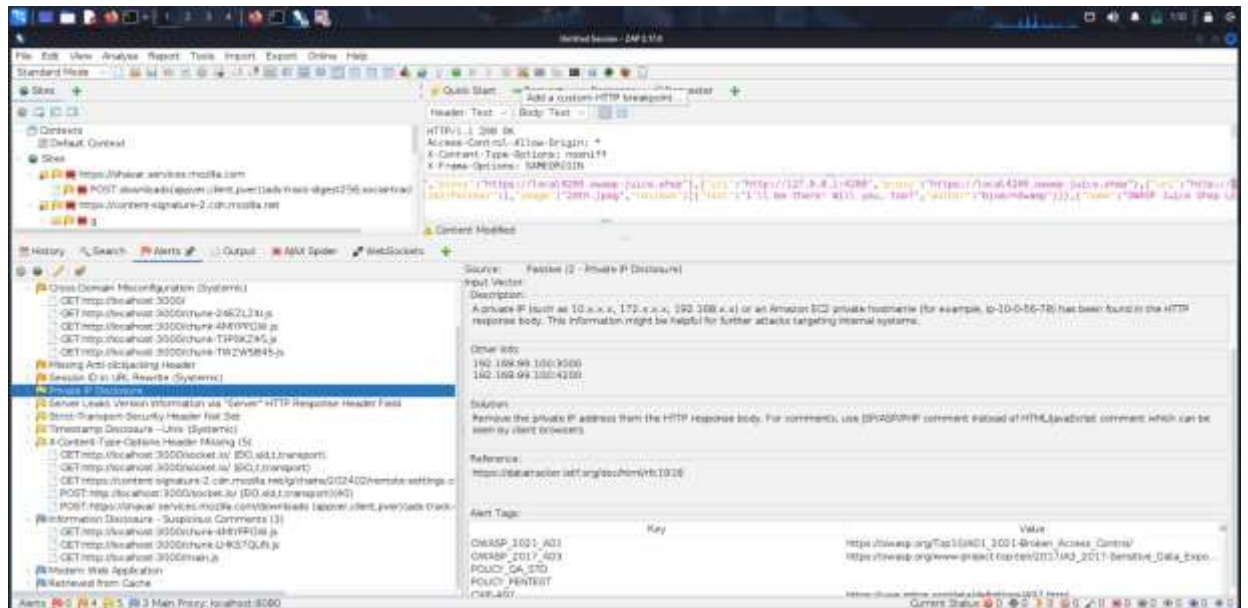
Session identifiers are exposed in the URL.

Impact:

Attackers can capture session IDs and hijack user sessions.

Recommendation:

- Store session IDs in secure cookies
- Avoid URL-based session tracking



FINDING 3

Vulnerability: Missing X-Content-Type-Options Header

Risk Level: Medium

Description:

The application allows MIME-type sniffing.

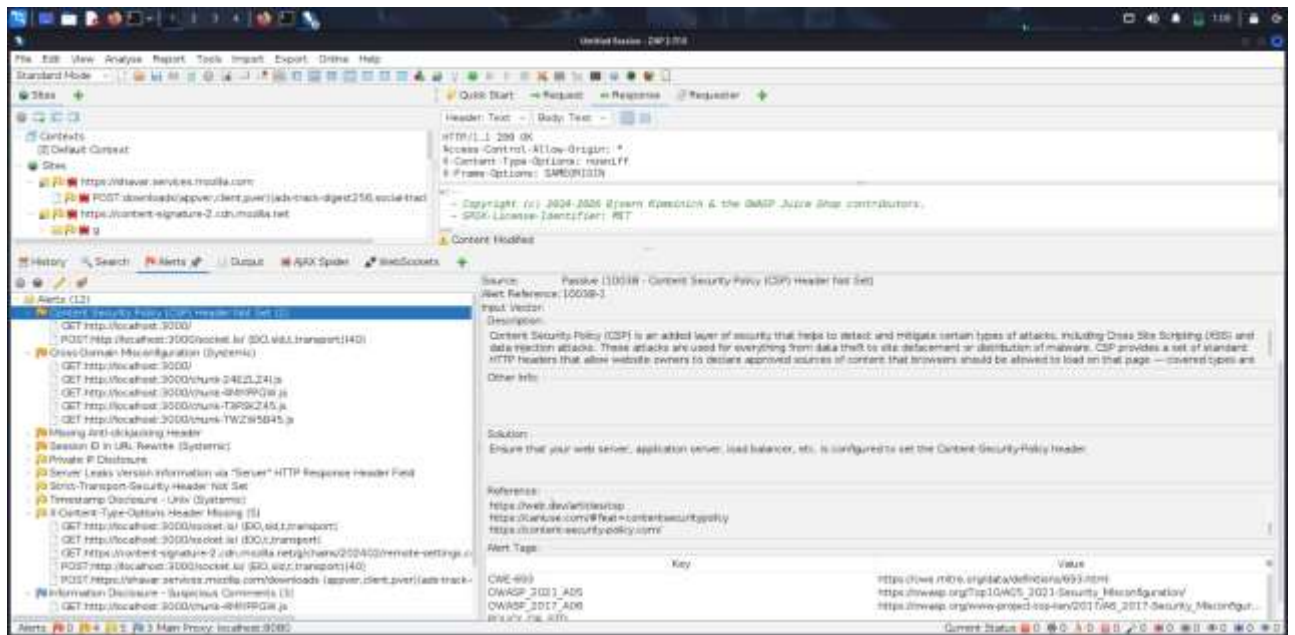
Impact:

Attackers may execute malicious files disguised as safe content.

Recommendation:

Add header:

X-Content-Type-Options: nosniff



FINDING 4

Vulnerability: Server Version Disclosure

Risk Level: Low

Description:

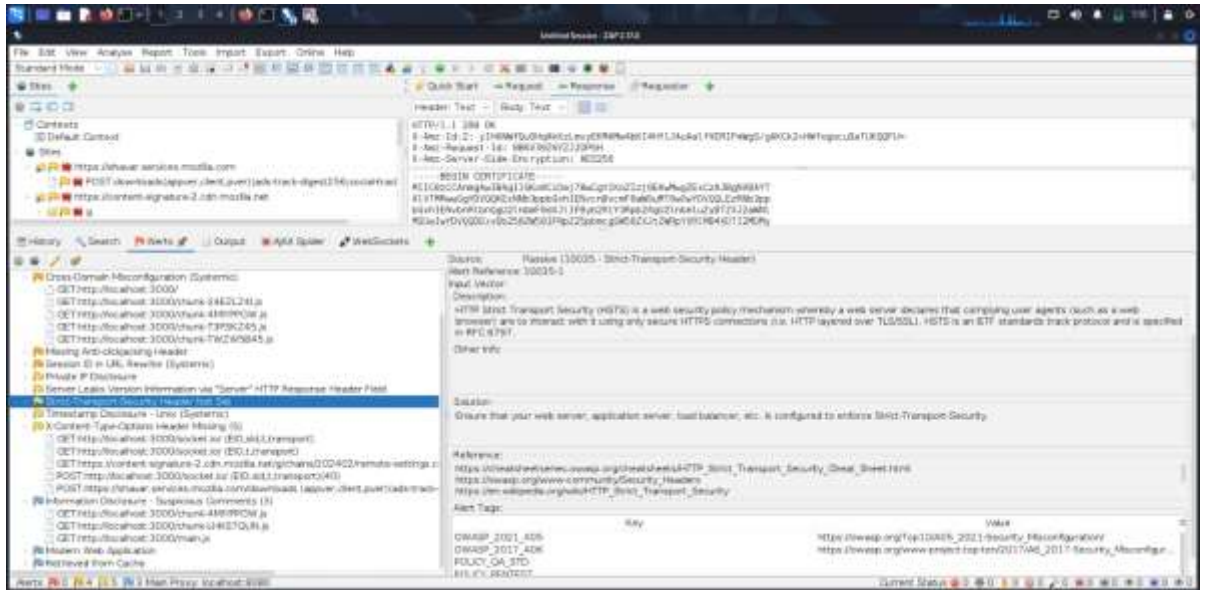
The server reveals version information in HTTP headers.

Impact:

Attackers can use this information to exploit known vulnerabilities.

Recommendation:

- Remove server version details
- Use generic server responses



FINDING 5

Vulnerability: Information Disclosure (Suspicious Comments)

Risk Level: Low

Description:

Sensitive or developer-related comments are visible in responses.

Impact:

Attackers may gain insights into application logic.

Recommendation:

- Remove unnecessary comments
- Avoid exposing internal details

CONCLUSION

The vulnerability assessment identified several medium and low-risk issues within the application. While no critical vulnerabilities were detected, the identified issues could still pose security risks if not addressed.

Implementing the recommended fixes will significantly enhance the application's security and reduce exposure to potential threats.